

HW04 Test Design Review — FR-02, FR-11, FR-14

Review scope

- Review date: 2026-08-07
- Student ID: 23127334
- Method: static review of requirements, UI/SUT implementation, Playwright specs, JSON data, and existing Chromium baseline evidence.
- Source code was not changed.
- Selected features:
 - FR-02 — Login and Account Lockout
 - FR-11 — User Order History
 - FR-14 — Category Management

Requirement sources

- FR-02: hw/eshop-sut/README.md , lines 38–45.
- FR-11: hw/eshop-sut/README.md , lines 160–168.
- FR-14 and admin access control: hw/eshop-sut/README.md , lines 174–189.
- Order API: hw/eshop-sut/api_specification.md , lines 139–147.
- UI/SUT:
 - frontend-web/src/pages/Login.jsx
 - frontend-web/src/pages/Profile.jsx
 - frontend-admin/src/App.jsx
 - backend/server.js

Coverage matrix

Feature-level matrix

Feature	Existing cases	Positive	Negative	Boundary/edge/state	Requirement coverage	Design status
FR-02	15	4	5	6	Login, failure counter, threshold, lock duration, token, email input	PARTIAL — three ambiguous/weak oracles and missing reset/Bearer checks
FR-11	12	8	2	2	Own-order list, fields, localization, status and cancellation UI	FAIL — TC-012 contradicts requirement; ownership is not directly proven; two API assertions can pass vacuously
FR-14	12	5	5	2	Add/view/delete, required name and unauthenticated mutation	PARTIAL — no successful UI add/delete; no non-admin authorization case; confirmation is unsupported by requirement

Requirement-to-test coverage

Requirement	Existing test IDs	Status	Gap
FR-02 valid login	001, 002	Covered	Add explicit authenticated-request/Bearer proof
Failed login increments exactly 1	011, 012, 013	Indirectly covered	No direct counter oracle; behavior inferred through threshold
Lock after 3 consecutive failures	012, 013, 014	Covered	TC-014 exact message oracle is stricter than requirement
Lock lasts 30 seconds	015	Covered	Fixed 31-second wait is slow and timing-sensitive
Successful login returns/stores JWT	001, 002	Partially covered	Token stored, but use in an authenticated request is not verified
Email input uses <code>type=email</code>	009	Covered	None
Successful login resets consecutive failures	011 only partially	Gap	Add failure → success → new failures sequence
FR-11 user sees only own orders	001 indirectly	Gap	Query only one account; no cross-user isolation oracle
FR-11 displays ID/date/amount/status	004, 006, 008–011	Covered with mocks	UI data is intercepted rather than integrated with backend
Status is Vietnamese and color differentiated	011	Covered	Class-count assertion proves difference, not correct class per status
Shipping order cannot be canceled by user	012	Incorrect	Test expects three cancel buttons including shipping; requirement allows only pending/confirmed
FR-14 admin can add category	002–004	API covered	No successful UI add and refresh/persistence check
FR-14 category list/view	001, 010	Partially covered	UI test checks heading, not created category row
FR-14 admin can delete category	009, 012	Not covered successfully	No create → delete → absence verification
FR-14 name is required/non-empty	005–007, 011	Covered	API and UI currently expose SUT defects
Data-changing category APIs require admin role	008	Partially covered	Missing valid non-admin token case
FR-14 “CRUD” implies Update	None	Ambiguous	Detailed requirement says Add/View/Delete only; seek lecturer clarification before treating Update as mandatory
Delete confirmation	012	Unsupported	Not stated in FR-14; treat as usability enhancement, not FR-14 defect

FR-02 detailed case review

Requirement summary

The user enters email and password. Every wrong login increments the consecutive failure counter by exactly one. Three consecutive failures lock the account for 30 seconds. Successful login returns a JWT stored client-side and used as a Bearer token. The email input must use `type="email"`.

Case matrix

ID	Type	Preconditions and data	Steps	Expected result	Isolation/setup/cleanup	Review
FR02-TC-001	Positive	Seeded customer <code>test@eshop.com</code>	Open login; submit valid customer credentials	Navigate to <code>/</code> ; greeting visible; token is a string	Depends on seeded account; no cleanup	Valuable; add proof token works on authenticated API
FR02-TC-002	Positive	Seeded admin <code>admin@eshop.com</code>	Submit valid admin credentials on web login	Navigate to <code>/</code> ; admin greeting; token stored	Depends on seeded admin	Valuable role partition, though admin access itself belongs to FR-12
FR02-TC-003	Negative	Unknown email	Submit unknown email and valid-looking password	Generic failure; remain on login	Independent	Valuable anti-enumeration case
FR02-TC-004	Negative	Register unique account; wrong password	Submit registered email with wrong password	Generic failure; remain on login	Unique account setup; account remains in DB	Valuable
FR02-TC-005	Negative	Register unique account; password with wrong case	Submit case-changed password	Generic failure	Unique account setup	Valuable password comparison partition
FR02-TC-006	Edge/ambiguous	Unique email decorated with leading/trailing spaces	Submit decorated email	Current oracle expects rejection	Unique account setup	Ambiguous: requirement does not say trim or reject spaces; document assumption or replace
FR02-TC-007	Negative validation	Empty email	Submit form with password only	Native required validation; no navigation	Independent	Valuable
FR02-TC-008	Negative validation	Empty password	Submit form with email only	Native required validation; no navigation	Independent	Valuable
FR02-TC-009	UI contract	Login page	Inspect email input	<code>type=email</code> and <code>required</code>	Independent	Directly required and valuable

ID	Type	Preconditions and data	Steps	Expected result	Isolation/setup/cleanup	Review
FR02-TC-010	UI/security contract	Login page	Inspect password input	<code>type=password</code> and <code>required</code>	Independent	Valuable security check, but <code>type=password</code> is not explicit in listed FR-02 text
FR02-TC-011	State/positive	Unique account; one failed attempt	Fail once; then submit valid password	Valid login succeeds	Unique account setup	Valuable below-threshold check
FR02-TC-012	Boundary	Unique account; two failed attempts	Fail twice; then submit valid password	Valid login succeeds	Unique account setup	Valuable threshold-minus-one check
FR02-TC-013	Boundary	Unique account	Submit wrong password three times; try valid password	Wrong attempts behave consistently; account becomes locked	Unique account setup	Valuable threshold check
FR02-TC-014	Negative/state	Unique locked account	Trigger lock; submit correct password in UI	Appropriate non-revealing locked response	Unique account setup	Exact Vietnamese text is stricter than "appropriate"; use semantic/error-code oracle if possible
FR02-TC-015	Edge/time	Unique locked account	Trigger lock; wait 31 seconds; submit valid password	Login succeeds after 30-second lock	Unique account setup; 31-second real wait	Required but slow/timing-sensitive; difficult, not impossible

FR-02 balance

- Positive: 001, 002, 011, 012.
- Negative: 003–008, 014.
- Boundary/edge/state: 006, 011–015.
- The suite exceeds 12 without cosmetic browser duplication.

FR-02 gaps

1. **Successful-login reset is not fully proven.** Add a sequence such as one failure → success → two new failures → success. It proves failures before a success do not remain in the next consecutive sequence.
2. **Bearer usage is not verified.** A string in local storage is insufficient to prove authenticated requests send `Authorization: Bearer <token>`.

3. **TC-006 has an unsupported oracle.** Requirements do not define trimming.
4. **TC-014 is overly text-specific.** The requirement defines appropriate, non-revealing feedback, not one exact sentence.
5. **TC-015 is hard but automatable.** The real-time wait is legitimate evidence for the demo requirement, but it is slow and should use polling/deadline logic without weakening the 30-second expectation.
6. **Cleanup:** unique accounts are not removed. They prevent collision but continuously grow the database.

FR-02 automation feasibility

Case	Feasibility	Reason
001–014	Automatable	UI and API outcomes are observable
015	Difficult but automatable	Requires real elapsed time or an approved controllable clock

FR-11 detailed case review

Requirement summary

A user may see only their own orders. The history displays order ID, creation date, total amount, and current status. Status labels must be clear Vietnamese labels and color differentiated. From the order-state requirement, users must not cancel an order in **shipping**; **delivered** and **canceled** are final.

Case matrix

ID	Type	Preconditions and data	Steps	Expected result	Isolation/setup/cleanup	Review
FR11-TC-001	Positive API	Seeded customer token	GET /api/orders/my-orders	200 and array	Depends on seeded customer/orders	Useful smoke test; does not prove ownership isolation
FR11-TC-002	Negative auth	No token	GET personal orders	401	Independent	Valuable
FR11-TC-003	Negative auth	Malformed token	GET personal orders	403	Independent	Valuable
FR11-TC-004	Positive schema	Authenticated seeded customer	GET personal orders; inspect first row if present	Required fields; no password	Depends on non-empty result	Weak/vacuous: if array is empty, field assertions never run
FR11-TC-005	Edge/order	Authenticated seeded customer	GET orders; compare adjacent IDs	Strict descending IDs	Depends on at least two orders	Weak/vacuous for zero or one order; ID order is an implementation proxy for newest
FR11-TC-006	Positive UI	Mocked sample orders and authenticated local state	Open profile	History heading visible	Mock isolated; no cleanup	Valuable but cosmetic alone

ID	Type	Preconditions and data	Steps	Expected result	Isolation/setup/cleanup	Review
FR11-TC-007	Edge UI	Mock empty response	Open profile	Helpful empty message	Mock isolated	Valuable empty-state partition
FR11-TC-008	Positive UI	Mock order ID 12	Open profile	#12 visible	Mock isolated	Valuable field rendering
FR11-TC-009	Positive UI	Mock ISO date	Open profile	Raw ISO absent; localized cell non-empty	Locale-dependent	Partial oracle: non-empty does not prove correct date
FR11-TC-010	Positive UI	Mock total 1,500,000	Open profile	Formatted amount and đồng symbol	Locale-dependent	Valuable
FR11-TC-011	Positive/edge UI	Five statuses	Open profile	Vietnamese labels and five distinct classes	Mock isolated	Useful; verify expected class per status, not only distinct count
FR11-TC-012	State/negative UI	pending, confirmed, shipping, delivered, canceled	Open profile; count cancel buttons	Current test expects 3 buttons	Mock isolated	Incorrect oracle: shipping must not be user-cancellable; expected count is 2

FR-11 balance

- Positive: 001, 004–006, 008–011.
- Negative: 002, 003.
- Edge/state: 005, 007, 011, 012.
- Numerical balance exists, but correctness and integration depth are insufficient.

FR-11 critical gaps

1. **TC-012 contradicts the requirement.** It currently expects cancellation for pending, confirmed, and shipping. The correct requirement-based oracle permits the action only for pending and confirmed.
2. **Own-order isolation is not directly tested.** Create/query orders for two users and prove user A never receives user B's order.
3. **TC-004 can pass without checking schema.** Deterministic setup must guarantee at least one order.
4. **TC-005 can pass vacuously.** Guarantee two or more orders and compare `created_at` or the documented ordering field.
5. **UI integration is mocked.** Preserve deterministic rendering tests, but add at least one genuine frontend → backend personal-history flow.
6. **Localized date oracle is weak.** Assert the expected localized date using a fixed locale/timezone strategy.
7. **Status colors:** map each status to the expected semantic class rather than merely expecting five different strings.
8. **Data-driven violation:** the order fixture array and credentials are inline in the spec.

Recommended 12 valuable FR-11 cases

ID/design	Type	Purpose
Keep 001	Positive	Authenticated list contract
Keep 002	Negative	Missing token
Keep 003	Negative	Malformed token
Strengthen 004	Positive	Guaranteed non-empty schema
Strengthen 005	Edge	Guaranteed newest-first ordering
Add ownership isolation	Security/negative	User A cannot see user B order
Keep 007	Edge UI	Empty history
Keep 008	Positive UI	Order ID
Strengthen 009	Positive UI	Exact localized date
Keep 010	Positive UI	Currency formatting
Strengthen 011	Edge UI	Exact label/color mapping
Correct 012	State/negative UI	No cancel for shipping/delivered/canceled

TC-006 heading may remain as supporting coverage but should not replace a business-rule case.

FR-11 automation feasibility

Area	Feasibility	Reason
API auth/schema/list	Automatable	Direct HTTP outcomes
Mock UI rendering	Automatable	Deterministic route interception
Cross-user ownership	Automatable with setup	Requires two users and orders
Real UI/backend history	Automatable with setup/cleanup	Requires deterministic order creation
Exact locale date	Automatable with controlled locale/timezone	Otherwise environment-sensitive

FR-14 detailed case review

Requirement summary and ambiguity

FR-14 is titled "Category CRUD," but its detailed requirement says an admin may **Add / View / Delete** categories and category name is required/non-empty. FR-12 additionally requires a valid JWT with `role=admin` for data-changing category APIs.

Therefore:

- Create, read/list, and delete are explicit.
- Update is supported by the backend but is not explicit in the FR-14 bullet.
- Update should be marked as a clarification/bonus case, not silently treated as a mandatory requirement until the lecturer confirms the meaning of "CRUD."
- Delete confirmation is not stated anywhere in FR-14.

Case matrix

ID	Type	Preconditions and data	Steps	Expected result	Isolation/setup/cleanup	Review
FR14-TC-001	Positive API	None	GET categories	200 and array	Independent	Valuable view/list contract
FR14-TC-002	Positive API	Admin token; unique ASCII name	POST category; GET list	Created ID/name present; delete cleanup	Good setup/cleanup	Valuable
FR14-TC-003	Positive/edge API	Admin token; Vietnamese name	POST; GET list	Unicode name preserved	Good setup/cleanup	Valuable encoding partition
FR14-TC-004	Boundary API	Admin token; one-character name	POST; GET list	Accepted	Good setup/cleanup	Requirement has no minimum; useful but lower priority
FR14-TC-005	Negative validation	Admin token; empty string	POST category	400	Current SUT inserts record; no cleanup on unexpected 200	Valuable; cleanup gap pollutes DB
FR14-TC-006	Negative validation	Admin token; missing property	POST 	400	Unexpected created row may remain	Valuable
FR14-TC-007	Edge/negative validation	Admin token; whitespace-only name	POST category	400	Unexpected created row may remain	Valuable interpretation of “empty”; trim rule should be stated
FR14-TC-008	Negative auth	No token	POST category	401	Independent	Valuable but insufficient for admin role
FR14-TC-009	Negative delete	Admin token; hardcoded missing ID	DELETE unknown ID	404	Independent	Reasonable API quality oracle, but not explicit in FR-14
FR14-TC-010	Positive UI	Admin session	Open category tab	Heading and active-tab style	Seeded admin	Mostly presentation; does not prove “View categories”
FR14-TC-011	Negative/UI contract	Admin session	Inspect new-name field/label	Native required constraint and visible required indication	Independent	Directly supports mandatory-name rule
FR14-TC-012	Usability	Admin session; existing first row	Click first delete; wait for dialog	Confirmation dialog	Risks arbitrary seeded deletion if behavior changes	Unsupported by FR-14; do not classify absence as FR-14 defect

FR-14 balance

- Positive: 001–004, 010.

- Negative: 005–009, 011.
- Edge/boundary: 003, 004, 007, 009.
- The count reaches 12, but successful UI workflows and admin-role enforcement are missing.

FR-14 critical gaps

1. **No successful UI add.** Add a unique name through the form and verify its row appears after refresh.
2. **No successful delete.** Create a unique category, delete exactly that row, then prove it is absent through UI and/or API.
3. **No valid non-admin authorization test.** A normal user token must receive 403 for POST/PUT/DELETE category operations under FR-12.
4. **TC-010 does not prove category viewing.** It checks heading/style only.
5. **TC-012 has no requirement basis.** Treat it as an exploratory usability case or replace it with successful delete.
6. **Unexpected creations are not cleaned up.** TC-005–007 currently leave invalid rows when the SUT wrongly returns 200.
7. **Hardcoded unknown ID is unsafe.** Dynamically determine a definitely absent ID or use a controlled ID namespace.
8. **Update ambiguity:** add an update test only as clarification/extended CRUD coverage until the lecturer confirms it is mandatory.

Recommended 12 valuable FR-14 cases

Proposed case	Type	Precondition/setup	Expected result
List categories API	Positive	None	200 array
UI displays category rows	Positive UI	At least one known category	ID and name visible
Create ASCII category API	Positive	Admin; unique data	Created and persisted
Create Vietnamese category API	Edge	Admin; unique Unicode	Preserved correctly
Create category through UI	Positive UI	Admin; unique data	Row appears after refresh
Empty name rejected	Negative	Admin	400/no row
Missing name rejected	Negative	Admin	400/no row
Whitespace-only rejected	Edge/negative	Admin	400/no row
Mutation without token rejected	Negative auth	No token	401
Mutation with customer token rejected	Security/negative	Customer token	403
Successful delete	Positive/state	Create unique category	Deleted and absent
Delete unknown ID	Edge/negative	Definitely absent ID	404

Optional after clarification:

- Update category name and verify persistence.
- Duplicate-name behavior, but only if uniqueness is specified.
- Delete confirmation as a usability enhancement, not an FR-14 oracle.

FR-14 automation feasibility

Area	Feasibility	Reason
API add/list/delete/validation	Automatable	Direct HTTP outcomes
UI add/view/delete	Automatable with unique data	Requires row-scoped locator and cleanup

Area	Feasibility	Reason
Admin-role enforcement	Automatable	Use seeded or registered customer token
Update	Technically automatable, requirement ambiguous	Requires lecturer clarification for mandatory status
Confirmation dialog	Automatable but unsupported	Should not be graded as FR-14 defect without requirement

Cross-feature design conclusions

Valuable case count after review

Feature	Current count	Cases with material design issues	Status toward 12 valuable cases
FR-02	15	TC-006 ambiguous; TC-014 overly exact; TC-015 slow	Likely sufficient after documenting/replacing weak oracles
FR-11	12	TC-004/005 vacuous; TC-012 incorrect; TC-006 cosmetic	Not yet 12 strong requirement-based cases
FR-14	12	TC-010 weak; TC-012 unsupported; successful UI/delete and role checks missing	Not yet 12 strong requirement-based cases

Independence and cleanup

Feature	Independent cases	Setup-dependent cases	Cleanup issue
FR-02	Validation/UI contract and unknown-email cases	Unique registered accounts for state tests	Accounts are never removed
FR-11	Missing/malformed-token and mocked UI cases	Seeded login/API cases	No deterministic creation/cleanup of real orders
FR-14	Public list and auth-negative cases	Admin mutations and UI cases	Unexpected invalid records can remain; TC-012 targets arbitrary first row

Cases difficult or impossible to automate

No selected requirement is inherently impossible to automate.

Case/area	Classification	Reason
FR-02 real 30-second expiry	Difficult	Real clock duration makes the test slow and timing-sensitive
FR-11 locale date	Difficult	Output changes with locale/timezone unless environment is controlled
FR-11 ownership isolation	Difficult setup	Requires two controlled users and distinguishable orders
FR-14 UI delete	Difficult setup	Must identify a unique row and guarantee cleanup
FR-14 Update as mandatory requirement	Blocked by ambiguity	Backend supports it, detailed FR text does not require it

Priority gaps before editing code

P0

1. Correct FR11-TC-012 to reject cancellation of `shipping`.
2. Replace or reclassify FR14-TC-012; confirmation is not a stated FR-14 rule.
3. Add cross-user ownership coverage for FR-11.
4. Add successful create/view/delete UI or integration coverage for FR-14.
5. Add non-admin mutation rejection for FR-14/FR-12.

P1

1. Make FR11-TC-004 and TC-005 non-vacuous with deterministic order setup.
2. Move FR-11 inline fixtures and credentials to external data.
3. Strengthen localized-date and status-color assertions.
4. Document or replace ambiguous FR02-TC-006.
5. Make FR02-TC-014 semantic rather than dependent on one exact sentence.
6. Add cleanup for unique accounts, orders, and unexpected category records.

P2

1. Seek lecturer clarification whether FR-14 requires Update because of the “CRUD” title despite the Add/View/Delete bullet.
2. Retain heading/style/confirmation tests only as supporting UI/usability coverage after 12 business-rule cases are secure.

Review decision

No test code should be edited until the student reviews these conclusions, especially:

- the corrected FR-11 shipping cancellation oracle;
- the removal/reclassification of FR-14 confirmation;
- the FR-14 Update ambiguity;
- the proposed replacement cases.

Implementation follow-up — 2026-08-08

The student requested implementation of the five P0 design corrections. Test and data files were updated; SUT code was not changed.

Requested correction	Implemented result	Chromium verification
FR11-TC-012 rejects shipping cancellation	Expected cancel-button count changed from 3 to 2; shipping/delivered/canceled rows require no button	Failed as intended: UI exposed 3 buttons, confirming the requirement defect
FR14-TC-012 becomes exploratory	Replaced mandatory-dialog assertion with report annotations recording whether confirmation was observed	Passed; absence of a dialog is no longer classified as an FR-14 failure
FR-11 cross-user ownership	Added FR11-TC-013 with two isolated customers and an order owned by the second customer	Passed; the first customer's history excluded the second customer's order ID
FR-14 successful create/view/delete	Added API delete persistence, UI create/view, and entity-scoped UI delete cases	FR14-TC-013, 014, and 015 passed
FR-14 customer-token mutation rejection	Added FR14-TC-016 expecting 403 and cleanup even when the SUT incorrectly creates data	Failed as intended: customer token received 200, exposing missing role enforcement

Final verification:

- TypeScript: passed (`tsc --noEmit`).
- FR-11 Chromium: 12 passed, 1 failed; only the corrected shipping oracle failed.
- FR-14 Chromium: 10 passed, 6 failed. The new successful workflow cases and exploratory case passed. FR14-TC-016 joined the five previously confirmed requirement failures.
- Services were stopped after verification.